

บทที่ 7

การพัฒนาโปรแกรมไฟร์เบรก

7.1 แนวคิด

ไฟร์เบรก (FireBreak) เป็นโปรแกรมซีเคียวริตี้เว็บพรีอ็อกซี่สำหรับเพิ่มความปลอดภัยให้กับเว็บเซิร์ฟเวอร์ซึ่งอยู่ภายในโซน DMZ ใช้ความสามารถของโปรแกรม squid-cache ในการทำงานเป็นรีเวิร์สเว็บพรีอ็อกซี่ทั่วไปและเพิ่มความสามารถในส่วนของการตรวจสอบการบุกรุกในระดับของแอปพลิเคชันของโปรแกรม snort_inline ซึ่งสามารถเก็บล็อกไฟล์ได้จะถูกส่งไปยังดาต้าเบสของเครื่องแม่ข่าย

7.2 ขอบเขตและความสามารถ

โปรแกรมนี้สามารถตรวจสอบแพ็คเกจที่จะเข้าสู่เว็บเซิร์ฟเวอร์ที่อยู่ข้างหลังได้ทำให้ผู้ที่ต้องการติดต่อกับเว็บเซิร์ฟเวอร์ไม่สามารถติดต่อได้โดยตรง ดังนั้นการที่จะโจมตีเว็บเซิร์ฟเวอร์โดยตรงจึงไม่สามารถทำได้ ทำให้การโจมตีที่เกิดขึ้นนั้นเกิดขึ้นกับตัวเครื่องที่ทำหน้าเป็นซีเคียวริตี้เว็บพรีอ็อกซี่แทน ซึ่งโปรแกรมนี้เป็นการรวมความสามารถของโปรแกรม Squid และ Snort_inline เพื่อเพิ่มความสามารถในการป้องกันการโจมตีหรือการบุกรุกต่างๆที่อาจเกิดขึ้นได้

แต่ความสามารถในการตรวจสอบของโปรแกรมนี้ยังมีข้อจำกัดอยู่บ้างเนื่องจากการที่จะหวังพึ่งแต่ความสามารถของ Snort_inline ในการตรวจสอบการบุกรุกทางแอปพลิเคชันหรือทางเว็บนั้นแต่เพียงอย่างเดียว คงไม่อาจทำให้เว็บเซิร์ฟเวอร์ หรือตัวเครื่องที่รันโปรแกรมนี้มีความปลอดภัยได้ทั้งหมด เนื่องจากการบุกรุกทางแอปพลิเคชันนั้นก็ได้มีการพัฒนาและมีรูปแบบต่างๆมากมาย ทำให้ต้องมีการอัปเดตตัว rule ของ Snort_inline อยู่เสมอ และขึ้นอยู่กับการเขียนโค้ดของเว็บเซิร์ฟเวอร์เองด้วยว่ามีการเขียนป้องกันการบุกรุกไว้ด้วยหรือไม่

7.3 การพัฒนาโปรแกรม

โปรแกรมไฟร์เบรกเป็นสามารถแบ่งการทำงานได้ออกเป็น 2 ส่วนคือ

1. โปรแกรม Squid ที่ทำเป็นรีเวิร์สเว็บพรีอ็อกซี่
2. โปรแกรม Snort_inline ที่ช่วยเพิ่มความสามารถในการป้องกันให้กับโปรแกรมนี้

7.3.1 โปรแกรม Squid

สำหรับความสามารถในการเป็นรีเวิร์สเว็บพร็อกซี่นี้ จะใช้ Squid-cache ซึ่งเป็นโปรแกรมแบบเปิดเผยแพร่สโตร์โค้ดสำหรับใช้งานเป็นเว็บพร็อกซี่ที่แพร่หลายโปรแกรมหนึ่ง ที่สามารถนำมาประยุกต์ใช้เป็นรีเวิร์สเว็บพร็อกซี่สำหรับเว็บเซิร์ฟเวอร์ได้

สามารถดาวน์โหลดซอร์สโค้ดเวอร์ชันล่าสุดของ Squid-cache ได้จากเว็บ

<http://www.squid-cache.org/> ซึ่งเวอร์ชันที่นำมาใช้นี้คือ เวอร์ชัน 2.5

Squid-cache มีลักษณะการตั้งค่าการใช้งานโดยต้องทำการแก้ไขในไฟล์ squid.conf ซึ่งอยู่ที่ `/etc/squid/squid.conf` ซึ่งในไฟล์มีคอมเมนต์อธิบายการใช้งานคำสั่งที่เกี่ยวข้องกับการตั้งค่าของ squid-cache ไว้อยู่แล้ว สำหรับการตั้งค่าของ squid-cache ในไฟล์ squid.conf ที่ใช้งานในโครงการนี้มีดังนี้

<code>http_port 80</code>	<code># reverse webproxy port</code>
<code>visible_hostname 192.168.1.1</code>	<code># IP Address of webserver</code>
<code>httpd_accel_host 192.168.1.1</code>	<code># IP Address of webserver</code>
<code>httpd_accel_port 80</code>	<code># webserver port</code>
<code>http_access allow all</code>	<code># permit any IP to connection</code>

คำอธิบายการใช้งานในส่วนต่างๆของไฟล์ squid.conf

- `http_port`

ใช้กำหนดพอร์ตที่จะติดต่อเข้ามายังพร็อกซี่มีค่าเริ่มต้นเป็น 3128 สำหรับรีเวิร์สเว็บพร็อกซี่

`http_port` ก็ต้องกำหนดค่าเป็น 80 ซึ่งเป็นพอร์ตทั่วไปในการใช้งาน HTTP

- `visible_hostname`

ใช้สำหรับระบุโฮสต์ที่เป็นเว็บเซิร์ฟเวอร์เมื่อเกิด `error_message` ในการทำงานของ squid กรณีที่ไม่สามารถระบุได้ว่าโฮสต์ที่เป็นเว็บเซิร์ฟเวอร์คือเครื่องใด

- `httpd_accel_host`

ใช้ระบุโฮสต์ที่เป็นเว็บเซิร์ฟเวอร์จริงๆ ในการทำเป็น Transparent Proxy

- `httpd_accel_port`

ใช้ระบุพอร์ตที่ใช้งานของเว็บเซิร์ฟเวอร์ ในการทำเป็น Transparent Proxy

- `http_access`

ใช้ระบุสิทธิ์ผู้ที่สามารถใช้งานรีเวิร์สเว็บพร็อกซี่นี้ได้ โดยค่าเริ่มต้นจะเป็น `deny all` แต่การใช้งานเป็นรีเวิร์สเว็บพร็อกซี่จะรองรับบริการทั้งจากภายในและจากอินเทอร์เน็ตเองจะสามารถเข้าถึงได้ จึงต้องเปลี่ยนเป็น `allow all`

ส่วนความสามารถในการ cache ของ squid นั้นไม่ได้นำมาใช้ในโครงการนี้เนื่องจากเว็บเซิร์ฟเวอร์ที่อยู่หลังรีเวิร์สเว็บพร็อกซีนั้นมีเพียงเครื่องเดียวจึงขอไม่กล่าวถึงการตั้งค่าในส่วนนี้

7.3.2 โปรแกรม Snort_inline

สำหรับความสามารถของระบบการตรวจจับผู้บุกรุกนั้นจะใช้ snort_inline ซึ่งเป็น Intrusion Prevention System (IPS) ที่มีความสามารถในการตรวจจับแพ็กเก็ตที่เป็นอันตรายต่อเว็บเซิร์ฟเวอร์และสามารถรีอปแพ็กเก็ตนั้นทิ้งได้ทันที โดย snort_inline นี้เป็นโปรแกรมแบบเปิดเผยแพร่ฟรีโค้ด

สามารถดาวน์โหลดซอร์สโค้ดเวอร์ชันล่าสุดของ Squid-cache ได้จากเว็บ http://prdownloads.sourceforge.net/snort-inline/snort_inline-2.3.0-RC1.tar.gz?download ซึ่งโครงการนี้ใช้ snort_inline เวอร์ชัน 2.3.0-RC1

โดยการติดตั้ง snort_inline สามารถดูคู่มือที่ช่วยในการติดตั้งและทดสอบการทำงานเบื้องต้นของ snort_inline ได้ที่ <http://linuxgazette.net/117/savage.html>

หลังจากการติดตั้ง snort_inline แล้วก็จะต้องทำการตั้งค่าการใช้งานที่เหมาะสมให้กับ snort_inline ได้ที่ไฟล์ snort_inline.conf ซึ่งอยู่ที่ /etc/snort_inline/snort_inline.conf โดยมีการตั้งค่าที่ต้องแก้ไขเพิ่มเติมดังต่อไปนี้

ข้อความเดิมที่มีอยู่ในไฟล์ snort_inline.conf ในบรรทัดเหล่านี้

```
var RULE_PATH /etc/snort_inline/drop_rules

output alert_full : snort_inline-full

output alert_fast : snort_inline-fsat
```

แก้ไขเป็นข้อความใหม่ดังนี้

```
var RULE_PATH /etc/snort_inline/rules

#output alert_full : snort_inline-full

#output alert_fast : snort_inline-fast

output database : log,mysql, dbname=snort user=snort password=123 host 192.168.1.100
```

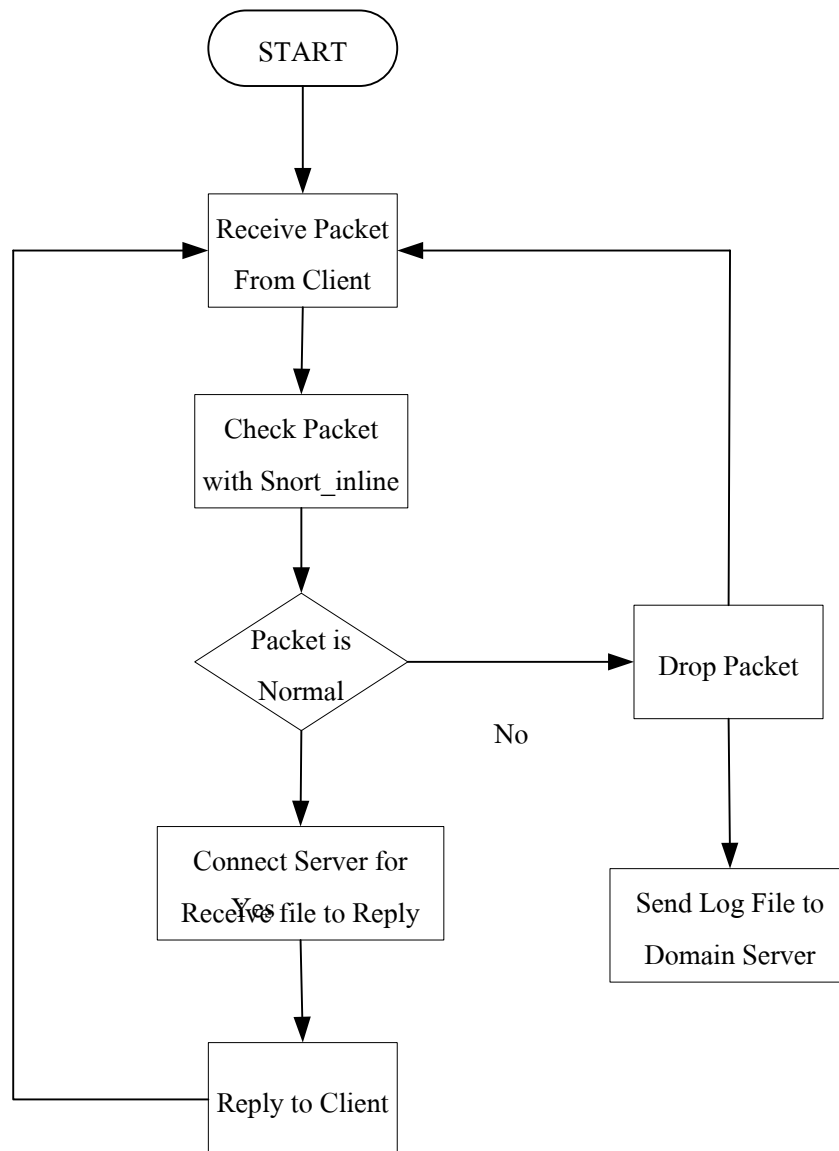
โดยในเครื่องแม่ข่ายจะต้องมีการลง mysql เวอร์ชัน 4.1 ที่มีการสร้าง database ชื่อ snort ในดาต้าเบสนี้สร้าง table ต่างๆโดยใช้ไฟล์ create_mysql ของ snort_inline และมีการสร้าง user ใหม่ที่รองรับการใช้งานของดาต้าเบส snort ชื่อ snort ที่กำหนด password ในการใช้งานคือ 123 โดยต้องกำหนดสิทธิ์ในการใช้งานของ user snort ให้สามารถทำการ select, insert ดาต้าเบส snort ได้

จากนั้นทำการอัปเดต signature หรือ rule ของ snort_inline ให้มีความสามารถในการป้องกันเว็บเซิร์ฟเวอร์ได้ โดยทำการโหลด rule ใหม่ ๆ สำหรับ snort_inline ได้ที่ <http://www.bleedingsnort.com/> สำหรับไฟล์ rule ที่สำคัญในการป้องกันเว็บเซิร์ฟเวอร์ คือ bleeding-web.rules, bleeding-expiot.rules, bleeding-scan.rules, bleeding-attack response.rules ซึ่งเมื่อทำการโหลดไฟล์เหล่านี้มาแล้วต้องมีการแก้ไขไฟล์ snort_inline.conf ให้รองรับการทำงานของ rules ใหม่เหล่านี้โดยเพิ่มการตั้งค่าดังนี้ในส่วน of drop rules

```
include $RULE_PATH/bleeding-web.rules
include $RULE_PATH/bleeding-expiot.rules
include $RULE_PATH/bleeding-scan.rules
include $RULE_PATH/bleeding-attack response.rules
```

7.4 การทำงานของโปรแกรม

สำหรับการทำงานของโปรแกรมไฟร์เบรคนี้เป็นไปดังรูปที่ 7.1 คือ หลังจากทำการตั้งค่าการใช้งานและทำการเปิดเซอร์วิสเริ่มการใช้งานของ Squid และ Snort_inline แล้วก็จะเท่ากับอยู่ในสถานะ START ในรูปที่ 7.2 เพื่อรอรับแพ็กเก็ตที่มาจากไคลเอ็นต์ที่ต้องการจะติดต่อกับเว็บเซิร์ฟเวอร์ที่อยู่หลังจากเครื่องรีเวิร์สเว็บพร็อกซีนี้ เมื่อได้รับแพ็กเก็ต Snort_inline จะทำการตรวจสอบแพ็กเก็ตนั้นกับ rule ที่มีอยู่ว่าเข้าข่ายพฤติกรรมที่ผิดปกติหรือไม่ ถ้าแพ็กเก็ตนั้นผิดปกติ Snort_inline จะทำการดรอปปแพ็กเก็ตนั้นทิ้งและทำการบันทึกลงล็อกไฟล์ส่งกลับไปยังเครื่องแม่ข่าย แต่ถ้าแพ็กเก็ตนั้นเป็นแพ็กเก็ตปกติจะทำการติดต่อกับเว็บเซิร์ฟเวอร์เพื่อรับไฟล์ที่จะต้องทำการตอบกลับให้กับไคลเอ็นต์ถ้าต้องมีการตอบกลับ แล้วจึงจะทำการส่งไฟล์ที่ได้รับจากเว็บเซิร์ฟเวอร์นั้นให้กับไคลเอ็นต์ต่อไป



รูปที่ 7.1 แสดงการทำงานของโปรแกรมไฟร์เบรก